Day 2: Nmap Service Discovery

Network Reconnaissance and Service Baseline Verification with Nmap

Field	Details
Intern Name	Amrita Pathak
Date	04 September 2026
Internship Track	SOC (Security Operations Center)

Contents

1. Objective 3
2. Tools and Environment 3
3. Metasploitable 2 Installation 3
4. Host Discovery 4
5. Port Scan 5
6. Service and Version Detection 6
7. Baseline Comparison: Expected vs. Discovered Services 9
8. Findings: Unexpected Exposure 10
    8.1 Critical: vsftpd 2.3.4 trojaned backdoor (port 21) - CVE-2011-2523 10
    8.2 Critical: unauthenticated root shell on port 1524 - "Ingreslock" backdoor 10
    8.3 Critical: UnrealIRCd 3.2.8.1 trojaned backdoor (ports 6667, 6697) - CVE-2010-2075 10
    8.4 Critical: distccd remote code execution (port 3632) - CVE-2004-2687 10
    8.5 High: anonymous FTP login enabled (port 21) 11
    8.6 High: additional plaintext and weak-crypto exposure 11
9. Recommendations 11
10. Conclusion 11

1. Objective

Run an Nmap scan against a lab virtual machine to identify live hosts, open ports, and running services. Compare the discovered services against the services intentionally present on the target and flag any exposure that would be considered unacceptable in a production environment.

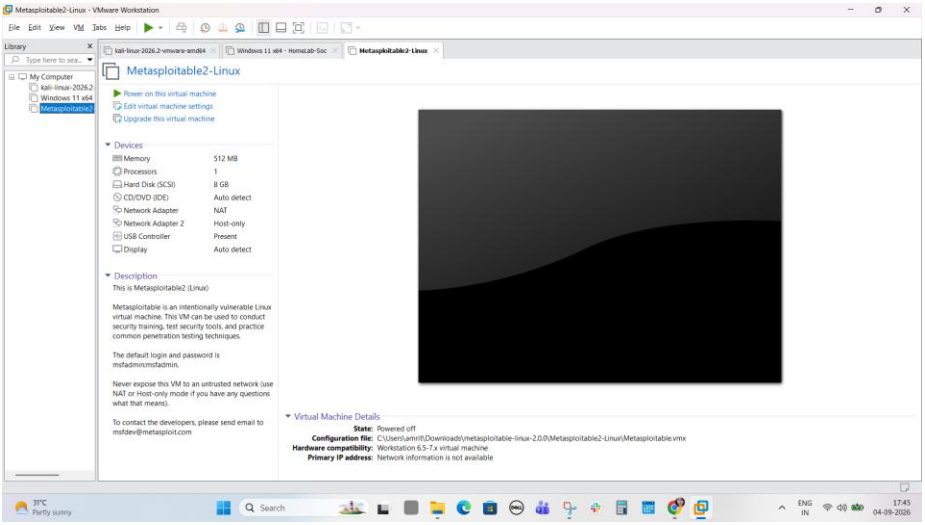
2. Tools and Environment

Item	Detail
Hypervisor	VMware Workstation Pro
Attacker / scanner VM	Kali Linux 2026.2 (192.168.84.128)
Target VM	Metasploitable 2 (192.168.84.130)
Network mode	VMware NAT, subnet 192.168.84.0/24
Primary tool	Nmap 7.99

The target and scanner were placed on the same isolated NAT network used in the earlier lab setup, so no traffic left the host machine at any point.

3. Metasploitable 2 Installation

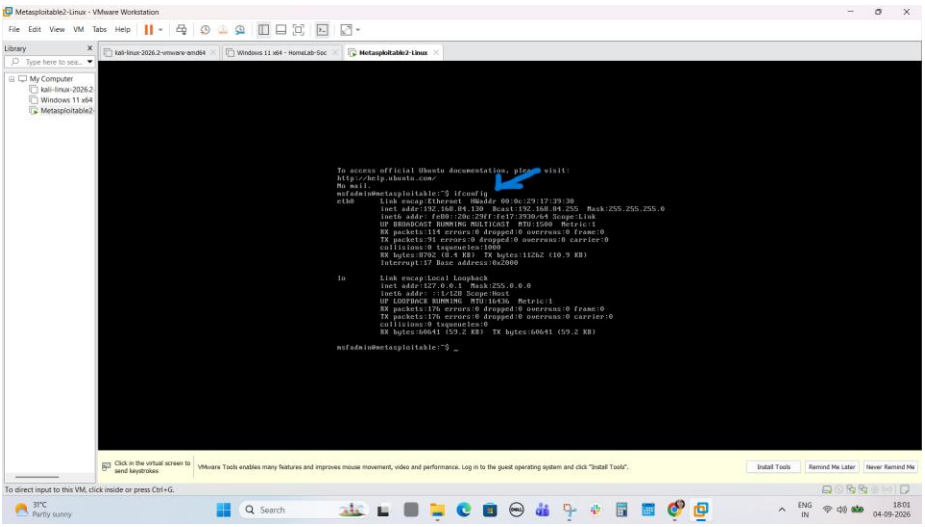
Metasploitable 2 was downloaded as a zipped VM image from the official SourceForge listing and extracted locally. Unlike the Windows 11 VM, it did not need the New Virtual Machine wizard, since it is a pre-built appliance rather than an OS to install from an ISO. It was added to VMware directly via File > Open, pointing to the extracted .vmx file, which brought up its VM summary page in the Library confirming it was recognized and ready to power on.



Metasploitable2-Linux imported into VMware Workstation: 512 MB memory, NAT and Host-only network adapters, and the vendor description confirming default credentials (msfadmin / msfadmin).

The VM was powered on and logged into at the console with those default credentials. With the VM running, its IP address was not yet known, since it had not been assigned one manually. The ifconfig command was run at the Metasploitable console to read the address DHCP had assigned to it.

```
ifconfig
```



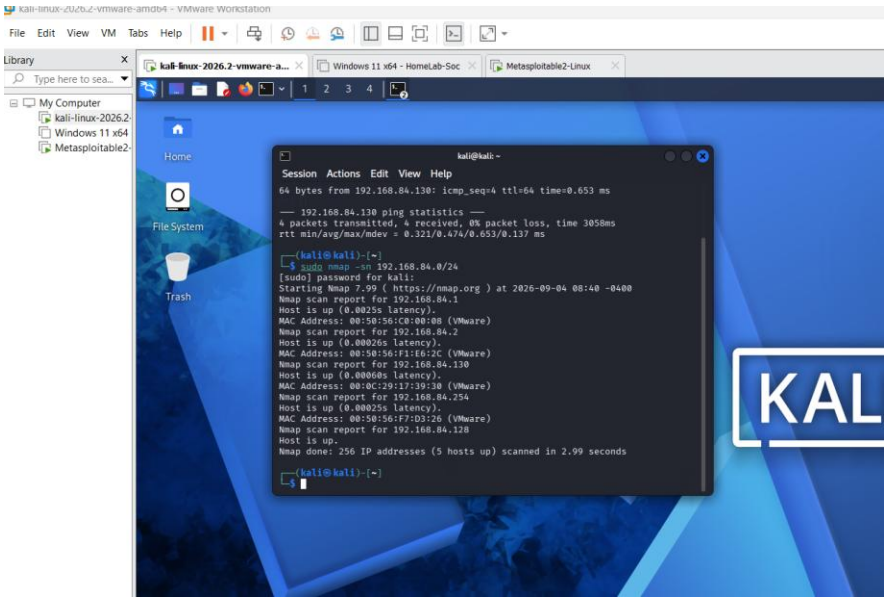
ifconfig output on Metasploitable showing eth0 assigned inet addr 192.168.84.130, in the same subnet as the Kali and Windows VMs.

With the target's IP address known, the Kali VM was brought to the foreground and used to ping 192.168.84.130 directly, confirming the two machines could reach each other before any scanning began. Only after this connectivity check succeeded did the host discovery and port scanning steps described below take place.

4. Host Discovery

A ping sweep was run across the full /24 subnet to confirm which hosts were live before scanning any single target.

```
sudo nmap -sn 192.168.84.0/24
```

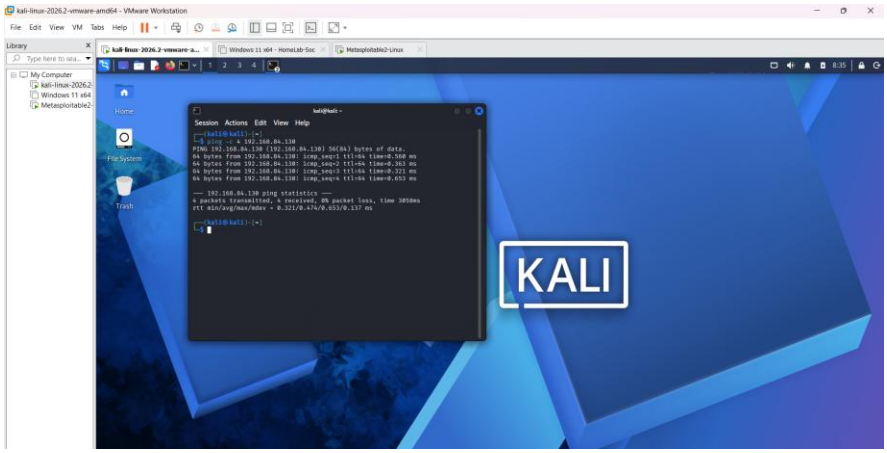


Host discovery sweep: 5 live hosts found on the subnet.

IP address	Role
192.168.84.1	VMware NAT gateway
192.168.84.2	VMware virtual DHCP / NAT service
192.168.84.128	Kali Linux (scanner)

IP address	Role
192.168.84.130	Metasploitable 2 (scan target)
192.168.84.254	VMware virtual network service

Only 192.168.84.130 is an actual lab target machine. The remaining addresses are VMware's own virtual networking infrastructure and were excluded from further scanning.

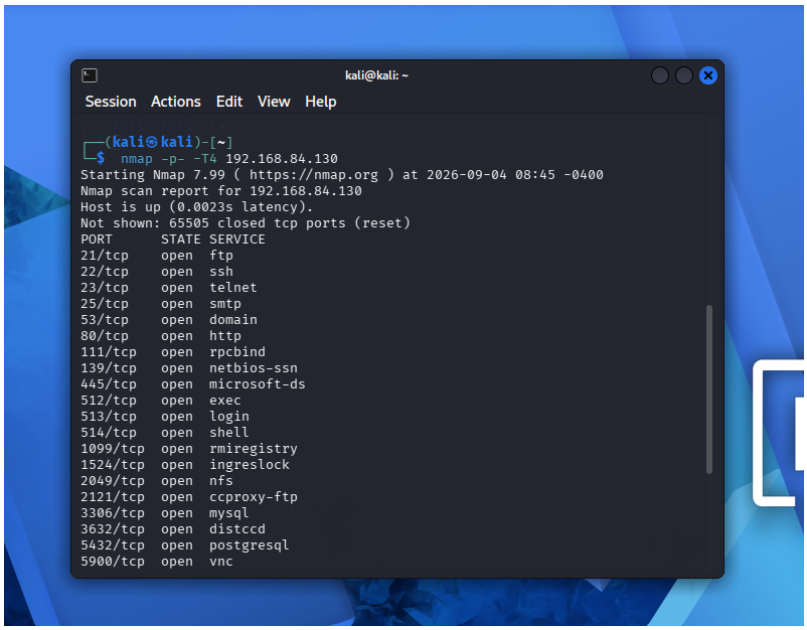


Connectivity confirmed from Kali to the target: 4 packets transmitted, 4 received, 0% packet loss.

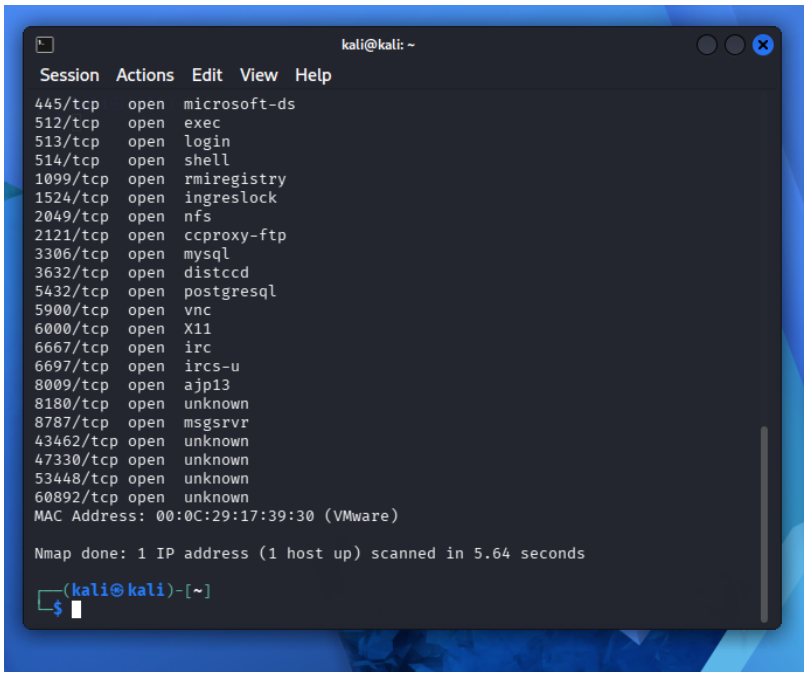
5. Port Scan

A full TCP port sweep (all 65,535 ports) was run against the target to make sure no open port outside the default top-1000 list was missed.

```
sudo nmap -p- -T4 192.168.84.130
```



Full port sweep result (part 1 of 2): open ports 21 through 5900.



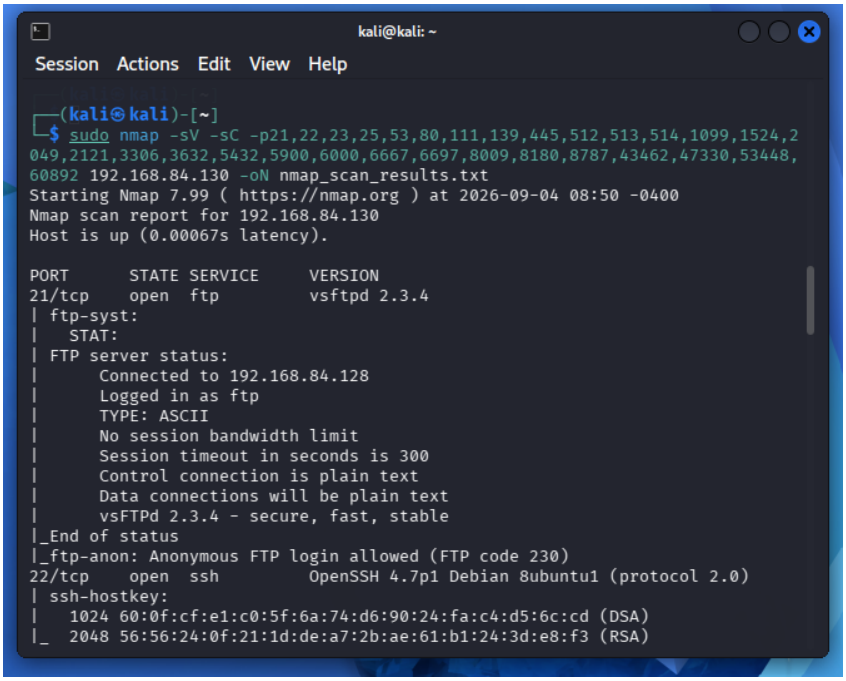
Full port sweep result (part 2 of 2): remaining open ports, 30 total, scan completed in 5.64 seconds.

30 open ports were found in total, well beyond what a default top-1000 scan would have shown.

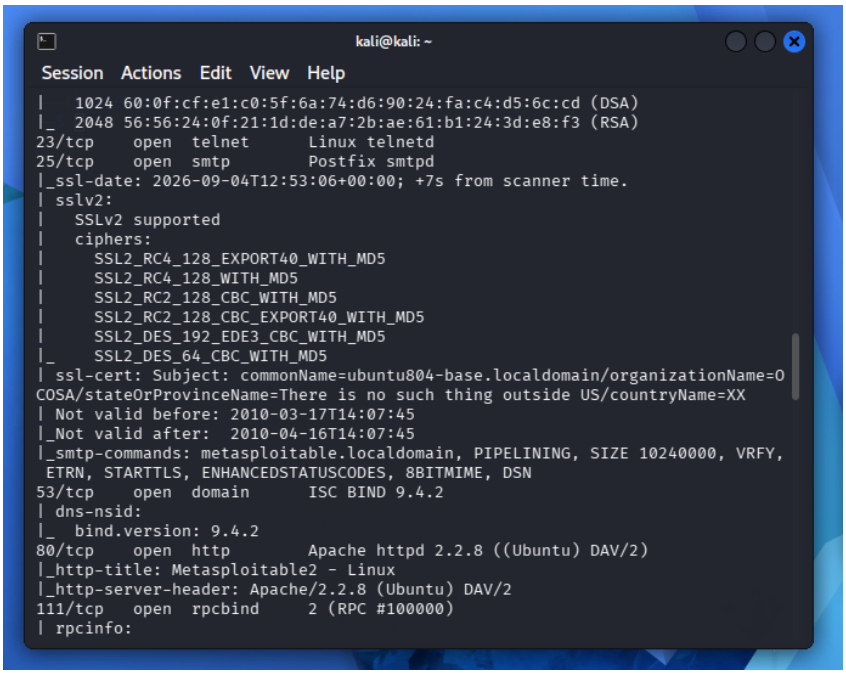
6. Service and Version Detection

Each open port was then re-scanned with version detection and Nmap's default safe scripts to identify the exact service, version, and any additional detail the scripts could surface.

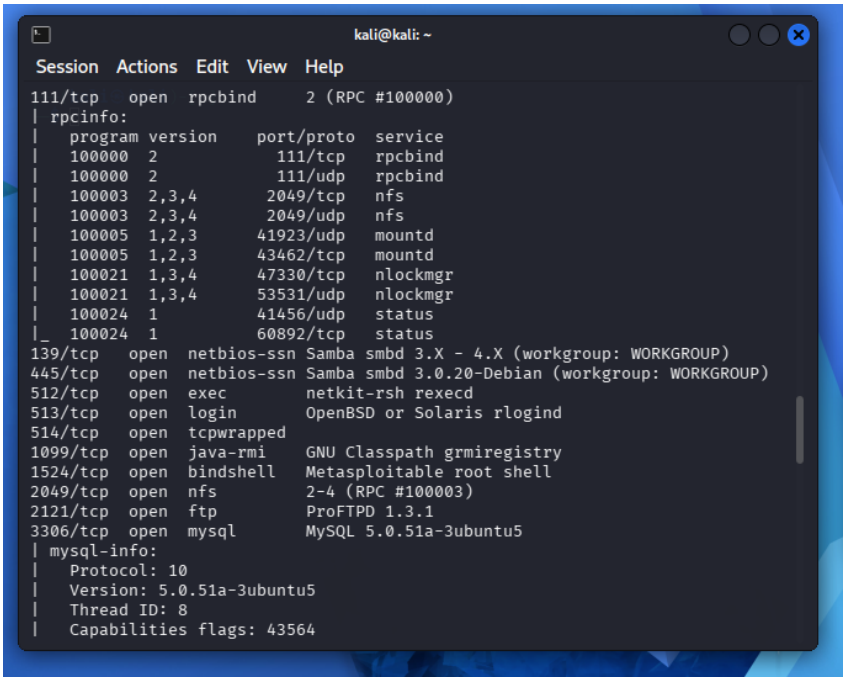
```
sudo nmap -sV -sC -p<open-ports> 192.168.84.130 -oN nmap_scan_results.txt
```



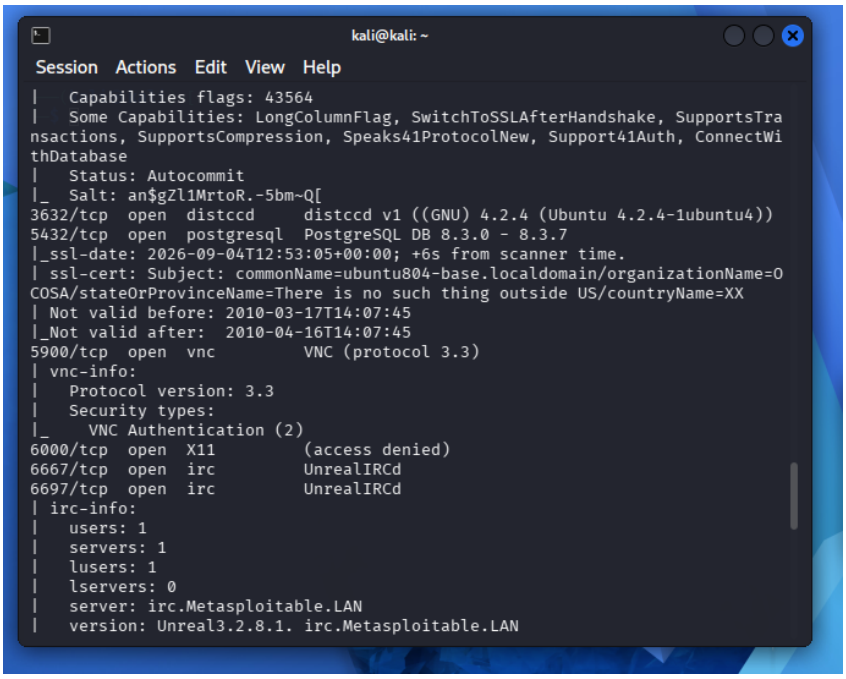
vsftpd 2.3.4 identified on port 21, with anonymous FTP login confirmed as allowed.



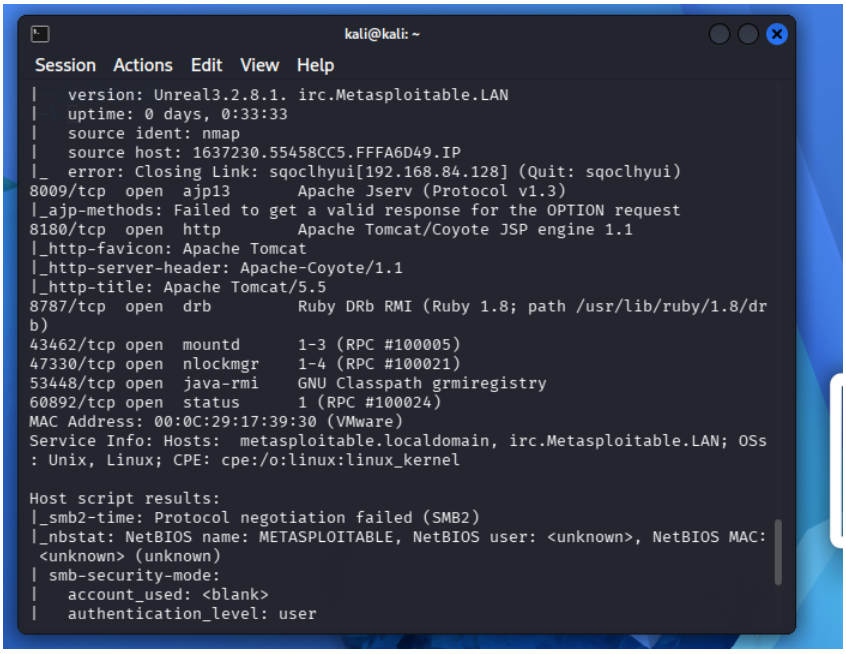
Telnet, Postfix SMTP with SSLv2 and weak export ciphers, ISC BIND, and Apache httpd identified on ports 23 through 111.



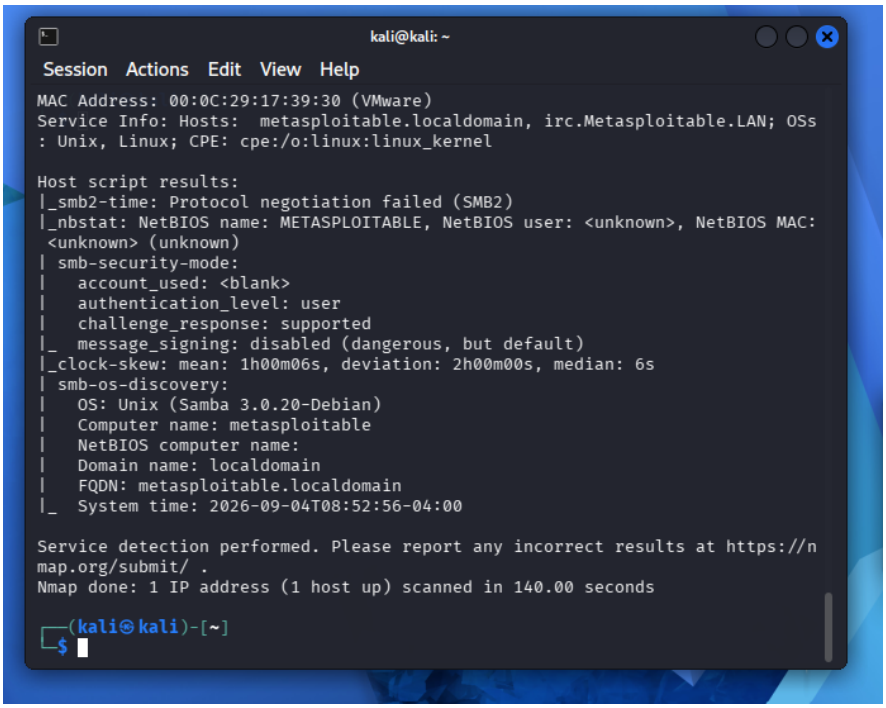
Port 1524 identified by Nmap itself as an unauthenticated bind shell ("Metasploitable root shell").



UnrealIRCd 3.2.8.1 identified on ports 6667/6697, and distccd identified on port 3632.



Ajp13, Ruby DRb, and RPC helper services identified, with SMB host script results beginning.



Scan completed in 140 seconds with full service detection across all 30 ports.

7. Baseline Comparison: Expected vs. Discovered Services

Metasploitable 2 is a deliberately vulnerable training image, so the baseline here is not a set of services configured by hand. It is the set of services Metasploitable's own documentation describes as intentionally included for practice. The table below lists every service discovered, whether it matches that intended baseline, and how it would be judged if this were a production host rather than a training lab.

Port	Service found	Baseline status	Production risk
21	vsftpd 2.3.4, anonymous login allowed	Expected (lab)	**Critical**
22	OpenSSH 4.7p1	Expected (lab)	Low
23	Telnet (plaintext)	Expected (lab)	**High**
25	Postfix smtpd, SSLv2 + export ciphers	Expected (lab)	**High**
53	ISC BIND 9.4.2	Expected (lab)	Medium
80	Apache httpd 2.2.8	Expected (lab)	Medium
111	rpcbind	Expected (lab)	Medium
139/445	Samba, SMB signing disabled	Expected (lab)	**High**
512-514	rexec / rlogin / rsh (r-services)	Expected (lab)	**High**
1099	Java RMI registry	Expected (lab)	Medium
1524	Unauthenticated root bind shell	Expected (lab)	**Critical**
2049	NFS	Expected (lab)	Medium
2121	ProFTPD 1.3.1	Expected (lab)	Medium
3306	MySQL 5.0.51a	Expected (lab)	Medium

Port	Service found	Baseline status	Production risk
3632	distccd (remote code execution)	Expected (lab)	**Critical**
5432	PostgreSQL 8.3	Expected (lab)	Medium
5900	VNC, weak auth	Expected (lab)	**High**
6000	X11	Expected (lab)	Medium
6667/6697	UnrealIRCd 3.2.8.1 (known backdoor)	Expected (lab)	**Critical**
8009	AJP13 (Tomcat connector)	Expected (lab)	Medium
8180	Apache Tomcat 5.5	Expected (lab)	Medium
8787	Ruby DRb	Expected (lab)	**High**
43462/47330/53448/60892	RPC helper services (mountd, nlockmgr, java-rmi, status)	Expected (lab)	Low

8. Findings: Unexpected Exposure

Every service above is part of the Metasploitable image by design, so nothing found was unauthorized in the strict sense. The value of this exercise is in correctly judging severity, not in finding surprises. Four findings stand out as unacceptable in any real production environment and are documented here as the critical findings a SOC analyst would escalate immediately, each verified against its public CVE record rather than assumed from the banner alone.

8.1 Critical: vsftpd 2.3.4 trojaned backdoor (port 21) - CVE-2011-2523

This is a separate and more serious issue than the anonymous FTP login noted below. In July 2011 the official vsftpd-2.3.4 source package hosted on its master site was replaced with a tampered copy. Any client that logs in with a username ending in a smiley face, for example "anything:)", causes the tampered binary to open a root command shell on TCP port 6200, with no password required. This is not a misconfiguration and cannot be fixed by disabling anonymous access. The version banner itself is the indicator, and the only real fix is to replace the binary with a clean build or upgrade past this release entirely.

8.2 Critical: unauthenticated root shell on port 1524 - "Ingreslock" backdoor

Port 1524 was originally registered to Ingres database lock management, but Nmap's own fingerprint on this scan correctly labeled it "Metasploitable root shell." A connection to this port returns a command prompt running as root with no authentication at all. Historically this exact port became a well-known signature left behind by attackers after a successful compromise, precisely because it required no credentials to reuse. Its presence here is intentional for training, but it stands in for what a SOC analyst should treat as a near-certain indicator of prior compromise if ever found on a real host: this is the kind of finding that triggers immediate isolation, not a ticket.

8.3 Critical: UnrealIRCd 3.2.8.1 trojaned backdoor (ports 6667, 6697) - CVE-2010-2075

Between November 2009 and June 2010 the official UnrealIRCd 3.2.8.1 source archive distributed from the project's own download servers was replaced with a modified copy. The modification adds a hidden command channel: any text sent to the IRC service beginning with a specific control sequence is executed directly as a system command, with no authentication. Like the vsftpd case above, this was a supply-chain compromise of the distributed binary itself, not a bug in the IRC protocol, so patching configuration settings does not help. Only replacing the binary with a clean, verified build resolves it.

8.4 Critical: distccd remote code execution (port 3632) - CVE-2004-2687

distcc is a tool for distributing compilation jobs across multiple machines. Its daemon mode, distccd, executes whatever compilation command it is sent without checking who sent it or whether they are authorized. When the daemon is reachable from the network, as it is here, any remote client can submit an arbitrary shell command disguised as a compile job and have it executed with the privileges of the distccd process. This CVE carries a CVSS base score of 9.3 and has a long history of active exploitation, since distcc is often left running on build servers that are otherwise trusted.

8.5 High: anonymous FTP login enabled (port 21)

Separately from the trojaned binary above, the FTP server itself was also configured to accept anonymous logins, confirmed in the scan output as "Anonymous FTP login allowed (FTP code 230)." This allows any unauthenticated client to browse the server's file listing. On a production host this alone, even with a clean vsftpd binary, would be treated as an unnecessary information disclosure risk and disabled.

8.6 High: additional plaintext and weak-crypto exposure

- Telnet on port 23 transmits all credentials and session data in plaintext, fully readable to anyone able to observe the traffic.
- SMTP on port 25 advertises SSLv2 support along with export-grade ciphers (RC4 and 40-bit DES), both broken by modern cryptographic standards and retained only for legacy compatibility.
- SMB on ports 139/445 has message signing disabled, flagged by Nmap itself as "dangerous, but default," which leaves the protocol open to relay attacks where a machine in the middle can impersonate either party.
- The r-services on ports 512 to 514 (rexec, rlogin, rsh) predate modern authentication entirely and transmit credentials in plaintext, the same category of risk as Telnet.

9. Recommendations

Framed as if this were a production host rather than a lab target, the following actions would be the standard remediation path:

- Isolate the host immediately if the port 1524 bind shell is ever found outside a training environment; treat it as an active compromise indicator, not a configuration issue.
- Replace the vsftpd and UnrealIRCd binaries with clean, verified builds rather than attempting configuration changes; both backdoors are embedded in the software itself, so patching settings will not remove them.
- Remove or firewall distccd entirely unless it is required on an isolated build network with strict access control.
- Disable Telnet and the r-services (rexec, rlogin, rsh) in favor of SSH, which is already present and correctly configured on port 22.
- Disable anonymous FTP login and migrate to SFTP or FTPS.
- Enforce SMB signing and disable SSLv2 and export-grade ciphers on SMTP.
- Verify package checksums against vendor-published hashes after any future download of security tooling, as both trojaned services in this scan were distributed from otherwise legitimate source repositories.
- Reduce the overall attack surface by disabling any service not explicitly required for the host's function, rather than leaving default installs running.

10. Conclusion

A full port sweep followed by targeted service and version detection identified 30 open ports on the target, all consistent with Metasploitable's intentionally vulnerable design. Four findings (trojaned vsftpd and UnrealIRCd binaries, the port 1524 root shell, and the distcc remote code execution path) represent critical-severity exposure that would demand immediate action outside a training environment. This exercise demonstrated the full reconnaissance-to-triage workflow: discovering live hosts, enumerating open ports, fingerprinting services, verifying findings against public vulnerability records, and judging each one against a baseline of what should and should not be exposed.